

TEST OF DESIGN:

Control ID	AC-01
Control Title	Quarterly User Access Review
Control Objective	Ensure active access remains appropriate and exceptions are removed promptly.
Control Description	Quarterly, the application owner reviews the complete active-user population, certifies access, and tracks removals to closure.
Control Owner	Application Owner
Risk Statement	Users may retain inappropriate access after role changes or termination.
Framework Mapping	NIST AC-2 / PCI DSS v4.0 Req 7.2.5
Frequency	Quarterly
Test of Design Procedures	1. Inspect policy documentation and standard operating procedures (SOPs) regarding User Access Reviews. 2. Inquire with the Application Owner to understand the end-to-end access review workflow, population generation, and revocation timelines. 3. Evaluate if the review criteria mandate validating least-privilege alignment against role definitions. 4. Evaluate if the process includes a mandatory SLA for access removal 5. Verify evidence is retained. 6. Verify ownership and approval responsibilities. 7. Assess whether the control addresses the stated risk.
Observation	Inquired with the Application Owner and inspected the 2026 User Access Review SOP. Confirmed the control design mandates a quarterly review of 100% active users extracted directly from Okta/IAM, requires manager sign-off, and enforces Jira-based SLA

	tracking for access revocations. The design adequately mitigates the stated risk..
TOD Conclusion	Design Effective

TEST OF EFFECTIVENESS:

Control ID	AC-01
Control Title	Quarterly User Access Review
Population Period	Q2 2026 (April 1, 2026 – June 30, 2026)
Population Source	IAM active user report
Population Size	Review Event (150 total active user access records reviewed)
Sampling Method	Haphazard Sampling (Selected across high-privilege roles, recent role transfers, and standard access)
Sample Size	25 users selected from the Q2 2026 review population
Evaluation Steps	1. Obtain the complete, unedited Q2 2026 active user population export generated from Okta/IAM. 2. Verify that the access review was initiated and completed within the designated quarterly window. 3. Inspect the review evidence (ticket/platform sign-off) to confirm the Application Owner certified all 25 sampled user access permissions. 4. Verify that the individual performing the quarterly access review is independent of the individual provisioning or modifying user access. 5. For any access revocations identified in the sample, inspect the corresponding Jira ticket logs to verify access was removed within the defined 48-hour SLA. 6. Verify overdue removals were escalated according to policy. 7. Re-perform access checks against the production IAM active user directory as of the review date to confirm revoked users no longer maintain active access.

Observation	Obtained the complete Q2 2026 active-user population (150 users) from Okta. Reconciled the population to the IAM user directory and selected a risk-based sample of 25 users, including privileged accounts, recent role transfers, and standard users. Verified management certification for all sampled users. Five sampled users required access removal; corresponding Jira tickets confirmed access was revoked within the 48-hour SLA. No exceptions were identified.
TOE Conclusion	Operating Effective
Auditor	Ishitha Michael
Review Date	July 26, 2026